

Chương 4 – Hệ mật mã khóa công khai

Public Key Cryptosystem
(phần 2)

4.3) Chữ ký số và hàm băm

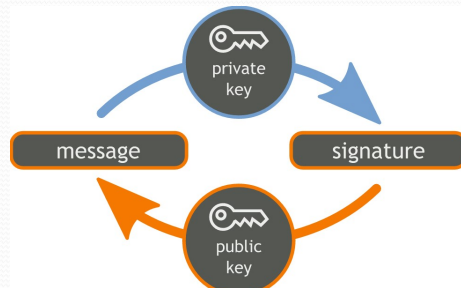
- Chữ ký số (digital signature) là một ứng dụng quan trọng của hệ mật mã PKC
- Chữ ký số được sử dụng trong , thay thế cho giao dịch qua giấy tờ truyền thống
- Sử dụng chữ ký số ngày phổ biến trong

Chữ ký để làm gì ?

- Chữ ký nhằm



Chữ ký tay



Chữ ký số

A) Nguyên lý cơ sở

Chữ ký viết tay

- Tạo một dấu ấn cá nhân viết tay có tính duy nhất lên văn bản
- Khi đã kí thì chữ ký gắn liền với văn bản, không thể tách rời
- Chữ ký ở dạng hình ảnh
- Kiểm tra chữ ký bằng nhận dạng hình ảnh
- Có thể giả mạo bằng cách sao chép

Chữ ký số

- Tạo ra bằng cách
- Chữ ký và văn bản
- Chữ ký
- Kiểm tra chữ ký

- Một hệ chữ kí số cần sử dụng 1 hệ mật mã PKC làm cơ sở để
- Nhờ tính bất đối xứng của cặp khóa, trong hệ chữ ký số
 - Khóa riêng K_D để
 - Khóa công khai K_E để

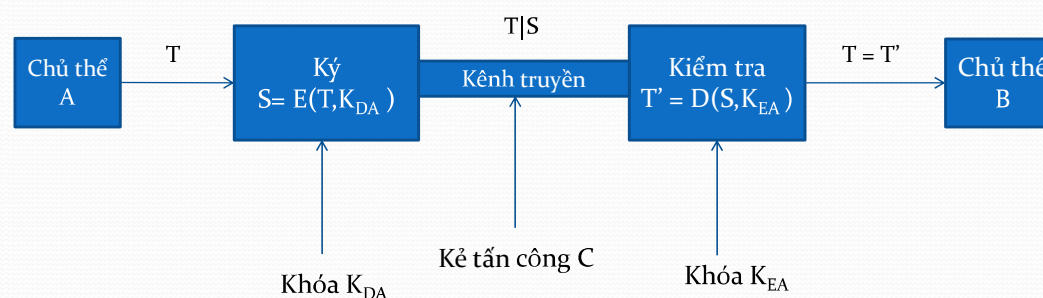
B) Sơ đồ tổng quát chữ ký số RSA

- Khởi tạo
 - Chủ thể có khóa riêng K_D và khóa công khai K_E
 - Chủ thể cần kí 1 văn bản T
- Tạo chữ ký S
 - $S = E(T, K_D)$ với E là hàm mã hóa RSA
 - S được

- Kiểm tra chữ ký cần có khóa công khai K_E
 - Tính $T' = D(S, K_E)$ với D là hàm giải mã RSA
 - S là chữ kí hợp lệ

Sơ đồ chữ ký số tổng quát

- Chủ thể A
- Chủ thể B



C) Ứng dụng của chữ ký điện tử

- Xác nhận lên
 - Chủ thể A phải ký một bản hợp đồng T
 - Để xác nhận đã ký, Alice tạo chữ kí S từ T và công bố cả T và S
- Kiểm tra chữ ký của chủ thể
 - Chủ thể B phải duyệt hợp đồng T mà A đã ký
 - B kiểm tra chữ ký S và hợp đồng T, rồi kết luận là S có phải chữ ký của A lên T hay không
- Chống chối bỏ trách nhiệm
 - Sau khi tạo chữ ký, chủ thể A không
- Bảo vệ tính toàn vẹn của văn bản gốc
 - Nếu có bất kì ai sửa đổi hợp đồng T trái phép thành T' sau khi A đã ký
 - Chủ thể B khi đối chiếu

D. Hàm băm mật mã

- Sử dụng chữ ký số với văn bản kích thước lớn có hạn chế sau
 - Độ dài chữ ký
 - Tốc độ
- Giải pháp: thu gọn văn bản trước khi ký bằng
 - Hàm băm H là một hàm
 - Input : bản tin M có độ dài bất kỳ
 - Output: chuỗi bit h có kích thước xác định (giá trị băm - hash value)

Tính chất

- (1) Từ giá trị băm h , không thể xác định bản tin gốc M
- (2) Nếu sửa đổi bản tin M , giá trị băm thu được cũng sẽ thay đổi
- (3) Gần như không thể tìm được hai bản tin khác nhau có cùng một giá trị băm h

E. Hàm băm mật mã kết hợp chữ ký điện tử

- 1) Trước khi ký, tạo một bản tin tóm tắt h của văn bản T bằng hàm băm mật mã

$$h = H(T)$$

- Bản tin tóm tắt đại diện cho văn bản gốc do

- 2) Tạo chữ ký S từ bản tin tóm tắt h và khóa riêng K_D
- 3) Đính kèm chữ ký vào văn bản: $T | S$

Kiểm tra chữ ký

- Input: $T | S$, hàm băm H và khóa K_E
 - Bước 1: Tính
 - Bước 2: Tính
 - Bước 3: Kiểm tra
if ($m=h$)
- Nếu văn bản T bị sửa đổi trái phép thì

F. Các dạng hàm băm mật mã phổ biến

- **MD5** (Message Digest 5):
- **SHA** (Secure Hash Algorithm) gồm 3 phiên bản
 - SHA-1: 160 bit
 - SHA-2:
 - **SHA-3**: 256, 384 và 512 bit

4.4) Quản lý khóa

- Trong cả 2 hệ mật mã đều tồn tại bài toán quản lý khóa
- Hệ SKC: Làm thế nào để A và B
- Hệ PKC: Làm thế nào để B

A) Trao đổi khóa đối xứng (khóa phiên)

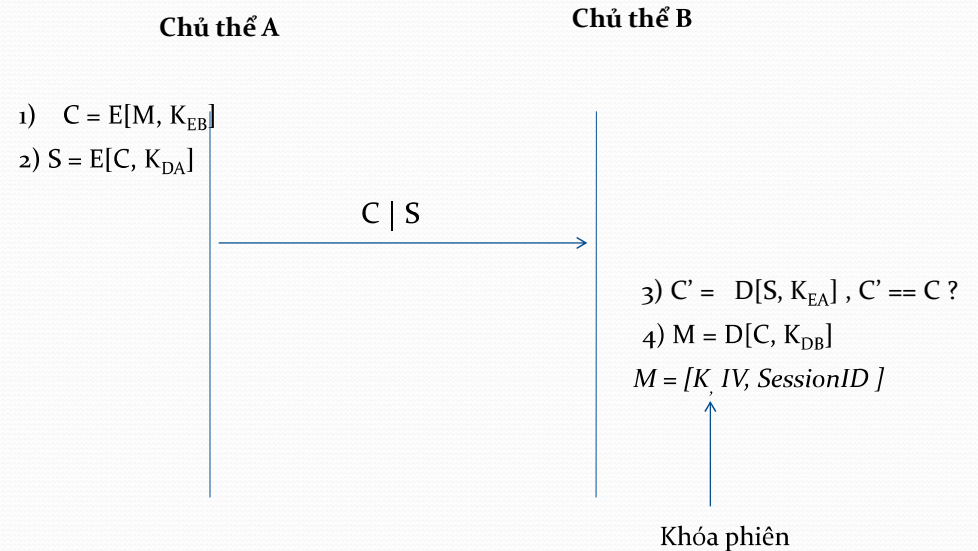
- Tình huống
 - Chủ thể A và B có nhiều phiên họp trực tuyến cần bảo mật thông tin
 - A và B sử dụng
- Khi bắt đầu 1 phiên, A hoặc B sẽ tạo ra khóa phiên K và trao đổi với nhau
- Khi kết thúc phiên,

Dùng PKC để trao chuyển khóa phiên

- Điều kiện ban đầu
 - A và B đã có khóa công khai của nhau là K_{EB} và K_{EA}
- Quy trình trao đổi khóa
 - A tạo ngẫu nhiên một khóa phiên K và vector IV
- A tạo một bản tin M gồm khoá K, vector IV và chỉ số của phiên *SessionID*

Sơ đồ trao chuyển khóa phiên bằng PKC

- A mã hóa M bằng khóa công khai K_{EB} của
- A tạo chữ ký số S để xác nhận C do A tạo ra
- A gửi C và S cho chủ thể B: $C | S$
- B kiểm tra chữ ký S:
- Cuối cùng, B giải mã C và có được khóa K

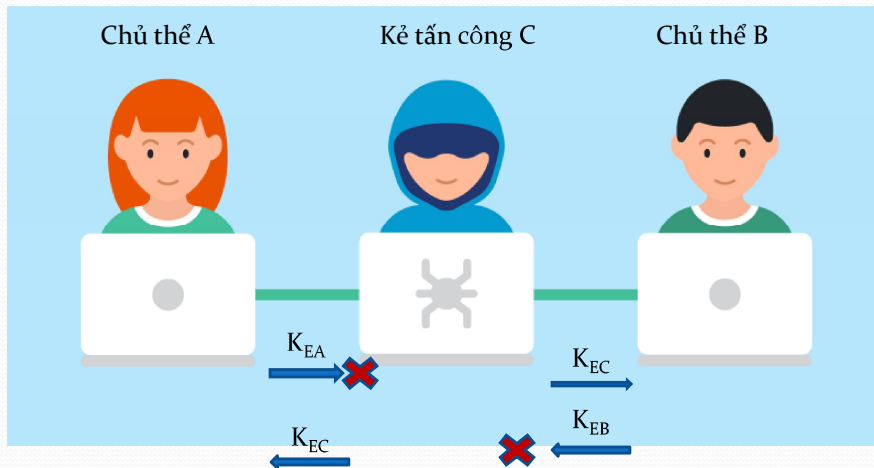


- Quy trình trao đổi khóa diễn ra an toàn, kẻ tấn công không thể làm lộ hay giả mạo khóa K
- Tuy nhiên, cần có điều kiện ban đầu là
- Nếu A và B chỉ đơn thuần trao đổi khóa công khai qua kênh truyền,

Tấn công Man in the Middle

- Kẻ tấn công C
- C chặn K_{EA} và gửi khóa công khai K_{EC} cho B
- Tương tự, C chặn K_{EB} và gửi khóa công khai K_{EC} cho A
- Do bị C tấn công, cả A và B đều nhầm tưởng K_{EC} là khóa công khai của đối tác và sử dụng khóa đó

Tấn công Man in the Middle



- Cách giải quyết:
 - Phải có 1 bên thứ 3 đáng tin cậy
 - Nếu có chứng nhận, chủ thể B sẽ
- Giải pháp hiện nay đang sử dụng là

B) Hạ tầng khóa công khai – chứng chỉ số

- Mục đích:
- Các nguy cơ mất an toàn đối với khóa công khai
- Hạ tầng khóa công khai và chứng chỉ số là cơ sở hạ tầng và các biện pháp kỹ thuật để quản lý chặt chẽ khóa công khai

Hạ tầng khóa công khai (Public Key Infrastructure) bao gồm

- Chứng chỉ số (digital certificate): là 1 chứng chỉ
- Cơ quan cấp chứng chỉ (Certificate Authority – CA) là một tổ chức có uy tín đứng ra
 - Cấp chứng chỉ số cho chủ thể
 - Quản lý các chứng chỉ đã cấp

Chứng chỉ số theo tiêu chuẩn ISO X.509

- Gồm các nội dung thông tin sau:
 - Số chứng chỉ: Serial number
 - Tên cơ quan CA phát hành: Issuer
 - Tên người được cấp: Subject
 - Thời hạn sử dụng:
 - Thông tin khóa công khai, hệ mật mã và độ dài của khóa. VD: RSA-2048
 - Chữ ký của CA (được tạo bằng khóa riêng của CA)

Quy trình

- Chủ thể A gửi đơn đề nghị cấp chứng chỉ số
- CA duyệt và ban hành chứng chỉ số xác nhận khóa công khai K_{EA} cấp cho A
- A gửi chứng chỉ số cho B

Xác minh chứng chỉ số

- B xác minh chứng chỉ số của A bằng
 - Nếu xác thực thành công, B có thể tin tưởng và sử dụng khóa công khai K_{EA} cho các giao dịch với A